Admin RBAC — team notice

Status: Live on **devapp** (`devapp.communityhealth.media`) and **prod** (`app.communityhealth.media`). Same model applies wherever the platform admin UI is deployed (including testapp when that env is in use).
Audience: Admins, Super Admins, ops, product, engineering.
Technical detail: admin-domain-cognito-groups.md

What's changing

Admin access is no longer "all or nothing."

Role	What you can do
ADMIN	**Read** every admin area (programs, payments, surveys, reports, content).
ADMIN + domain write access	Read everything, **and** create / update / delete in the domains you've been granted.
SUPER_ADMIN	Full write across all domains, plus promote/demote users and grant domain write access.

Important: Existing Admins keep **read** access after this change. They do **not** automatically keep write. Write must be granted per domain (no grandfathering).

Write domains

Domain	Examples of write actions	Cognito group
Payments	Pay now, hold/release, bulk payout, manual payout, delete payment	`cht-admin-payments`
Programs	Programs / webinars, registrations, invites, email overrides, Zoom recordings writes	`cht-admin-programs`
Surveys	Create / update / delete surveys, ensure / clone, comment tags	`cht-admin-surveys`
Reports	Generate, regenerate, refresh campaign reports	`cht-admin-reports`
Content	Content Hub campaign mutations, KOL admin mutations	`cht-admin-content`

Role changes (promote to Admin / Super Admin, delete elevated accounts) stay **Super Admin only**.

What you'll see in the UI

- Mutate buttons stay **visible** so the UI layout doesn't change by role.
- Without the matching write domain, controls are **disabled**.
- Hover / click should explain which access is missing (which Cognito group / domain).
- After you're granted access, **log out and back in** (or hard-refresh) so your session picks up the new capabilities.

How to get write access

1. Ask a **Super Admin**.
2. They open **Admin → Users**.
3. In the **Admin write access** panel, they toggle the domains you need (payments, programs, surveys, reports, content).
4. You sign out / sign in once.

Super Admins always have all domains checked (locked on); they don't need per-domain toggles.

Fallback for eng/ops: add the user to the matching Cognito group in the env's user pool — see the runbook.

Going forward — practices

1. **Default new staff to Admin (read-only).** Grant only the write domains their job needs.
2. **Prefer least privilege.** Finance → payments; program ops → programs (+ surveys if they edit forms); reporting → reports; content / Hub → content.
3. **Use Super Admin sparingly.** Super Admin can grant write and change roles — keep that circle small.
4. **Expect 403s on APIs** if someone calls a mutate endpoint without the domain capability (UI should already disable those actions).
5. **Session refresh after grants.** Cognito groups sync into `adminCapabilities` on login / `/auth/me` ; stale sessions look like "I still can't click Pay now."
6. **First Super Admin** on a fresh env (if needed): `POST /api/admin/bootstrap` with `ADMIN_BOOTSTRAP_SECRET` — then manage everyone else from **Admin → Users**.

Quick FAQ

I used to be able to Pay now / publish / generate reports and now I can't.
You still have Admin read. Ask a Super Admin to enable the matching write domain, then re-login.

Why are disabled buttons still showing?
By design — we disable, not hide, so everyone sees the same screens and knows what exists.

Can an Admin promote someone else to Admin?
No. Only Super Admin can change roles or grant domain write access.

Does this affect HCP / KOL learners?
No. This is admin-console RBAC only.

Owners

Topic	Who
Grant / revoke write domains	Super Admins
Cognito groups / pool issues	Platform engineering
Product questions (who should have which domain)	Product + ops leads